

MISSION 1
BTS SIO SISR

Nils HAMITOUCHE

DOSSIER DE MISSION PROFESSIONNELLE
ÉPREUVE E5

VERSION 2 — COMPTE RENDU DE DEUXIÈME REFONTE

Optimisation globale, segmentation Wi-Fi par portail captif, service SIEM et refonte de la gestion des identités hybrides (Active Directory / Microsoft Entra ID) avec MFA matériel (YubiKey) et logiciel

Candidat : Nils HAMITOUCHE

Formation : BTS SIO - Option SISR

Session : 2025-2027

Année de réalisation : 2026

Entreprise d'accueil : Intersport France - Siège de Longjumeau

Lieu : Longjumeau

TABLE DES MATIÈRES

TABLE DES MATIÈRES	2
PARTIE 1 - PRÉSENTATION DU CONTEXTE PROFESSIONNEL	3
1. Présentation de l'entreprise	3
2. Organisation du service informatique.....	3
3. Situation initiale, constats et limites de la première refonte	3
PARTIE 2 - ANALYSE DES BESOINS ET OBJECTIFS DE LA DEUXIÈME REFONTE	5
1. Objectifs principaux et évolution cyber.....	5
2. Contraintes d'implémentation et gestion du parc	5
3. Analyse des risques et retour d'expérience (Incident Phishing 2026)	5
PARTIE 3 - ARCHITECTURE CIBLE ET SERVICES DE SÉCURITÉ DÉPLOYÉS	6
1. Schéma général de l'infrastructure évoluée	6
2. Segmentation Wi-Fi et Portail Captif (VLAN 30)	6
3. Gestion de la Cybersécurité opérationnelle : Le Service SIEM (VLAN 20).....	6
4. Refonte de l'Annuaire : AD Local, Synchronisation Entra ID et Stratégie MFA multi-terminaux (YubiKey & Authenticator).....	6
Restructuration de l'Active Directory Local	7
Activation de l'Identité Hybride via Microsoft Entra ID	7
Mise en production de la Stratégie d'Authentification MFA Multi-Terminaux	7
PARTIE 4 - COMPTE RENDU DE DÉPLOIEMENT ET TECHNIQUE DE MIGRATION.....	8
1. Phase préparatoire et restructuration des Unités Organisationnelles (UO)	8
2. Cinématique de migration et enrôlement MFA.....	8
3. Conduite du changement et sensibilisation des collaborateurs	8
PARTIE 5 - RÉSULTATS, TRAÇABILITÉ ET BILAN PROFESSIONNEL.....	9
1. Analyse des résultats et indicateurs cyber	9
2. Compétences SISR validées et valorisation personnelle	9
3. Évolutions futures du système	9
CONCLUSION GÉNÉRALE.....	10

PARTIE 1 - PRÉSENTATION DU CONTEXTE PROFESSIONNEL

1. Présentation de l'entreprise

Intersport France est un leader incontournable de la distribution d'articles de sport sur l'ensemble du territoire national. La structure organisationnelle de l'entreprise s'appuie sur son siège social d'envergure nationale localisé à Longjumeau. Ce pôle centralise l'intégralité des fonctions névralgiques du groupe, à savoir la direction générale, les services financiers, la gestion des ressources humaines, la logistique macroéconomique, le pôle marketing/offre ainsi que la direction des systèmes d'information (DSI).

Le système d'information de Longjumeau est l'élément moteur de l'activité commerciale globale. Il supporte en continu les applications critiques de gestion des stocks logistiques, d'ordonnancement des ventes, d'administration centralisée du personnel, ainsi que l'ensemble des flux d'interconnexions et de communication unifiée intra-groupe.

2. Organisation du service informatique

La DSI s'articule autour de pôles de compétences hautement spécialisés : support de proximité et gestion du parc informatique, techniciens d'exploitation système, ingénierie infrastructure et réseaux, cellule cybersécurité (SOC / Gouvernance) et gestion de projets transverses. Le pôle infrastructure et réseaux est investi des missions critiques d'administration des serveurs physiques et virtualisés, de la cohérence du routage et de la commutation, ainsi que de la pérennité de la politique de sauvegarde.

Au regard de l'exposition d'Intersport France, la sécurité des infrastructures constitue un axe prioritaire. Toute altération de la disponibilité, de l'intégrité ou de la confidentialité des données pourrait se traduire par des ruptures de la chaîne logistique, des pertes financières lourdes et un préjudice réputationnel majeur.

3. Situation initiale, constats et limites de la première refonte

À la suite d'une première refonte d'infrastructure, le périmètre réseau avait bénéficié d'une nette amélioration des performances globales et d'une première modélisation des accès. Néanmoins, l'analyse post-implémentation menée début 2026 a révélé des vulnérabilités critiques subsistantes sur les couches hautes du modèle OSI, empêchant l'atteinte d'un niveau de protection aligné sur les exigences "Zero Trust".

Les limites majeures formalisées lors de cet audit étaient les suivantes :

- **Faiblesse du Wi-Fi Invités/Mobiles** : L'accès sans fil reposait sur une clé partagée (WPA2-PSK), générant un risque d'interception des flux et un défaut flagrant d'identification des tiers (invités, prestataires).
- **Déficit de visibilité cyber** : Les journaux d'événements (logs) des équipements restaient locaux et isolés, rendant impossible la détection de signaux faibles ou de mouvements latéraux malveillants.

- **Obsolescence et rigidité de l'annuaire** : L'Active Directory (AD) local présentait une arborescence d'Unités Organisationnelles (UO) désuète, compliquant l'application de stratégies de groupe (GPO) restrictives. De plus, l'absence de synchronisation avec le cloud et l'absence d'authentification multifacteur (MFA) exposaient l'entreprise au vol d'identités par force brute ou ingénierie sociale.

PARTIE 2 - ANALYSE DES BESOINS ET OBJECTIFS DE LA DEUXIÈME REFONTE

1. Objectifs principaux et évolution cyber

L'objectif absolu de cette deuxième refonte consiste à élever de manière disruptive le niveau de sécurité cyber du siège d'Intersport France en se conformant scrupuleusement au paradigme de sécurité « Ne jamais faire confiance, toujours vérifier » (Zero Trust). Il s'agit d'étendre la sécurité au-delà du périmètre physique en protégeant les couches réseaux, les terminaux volants et le cycle de vie complet des identités numériques des collaborateurs.

Le projet se décline en trois axes majeurs : l'assujettissement des flux Wi-Fi non-système à un contrôle strict par portail captif, la centralisation des métriques de sécurité au sein d'un puits de corrélation de logs, et la refonte intégrale de la structure de l'annuaire couplée à un mécanisme MFA robuste et universel, adapté à la typologie de chaque utilisateur.

2. Contraintes d'implémentation et gestion du parc

La mise en œuvre technique a dû composer avec des contraintes opérationnelles et matérielles rigides :

- **Continuité d'activité absolue** : La restructuration de l'annuaire AD et la bascule MFA ne devaient engendrer aucune interruption de service pour les terminaux logistiques et les services métiers.
- **Hétérogénéité des équipements utilisateurs** : Le personnel d'Intersport présente des profils variés. Certains collaborateurs disposent d'un ordiphone professionnel (smartphone), tandis que d'autres, notamment en zone logistique ou technique, ne possèdent pas de terminal mobile d'entreprise. La solution MFA choisie devait impérativement couvrir ces deux cas de figure de manière totalement étanche et sécurisée.

3. Analyse des risques et retour d'expérience (Incident Phishing 2026)

L'urgence de cette deuxième refonte a été accentuée par une compromission bien réelle survenue au sein de l'entreprise en février 2026. Une attaque par ingénierie sociale de type hameçonnage (phishing) ciblé avait permis l'usurpation de plusieurs identifiants de collaborateurs, entraînant des tentatives d'exfiltration de données et des mouvements latéraux au sein du réseau interne.

Cet incident a mis en exergue le fait qu'un mot de passe simple, même robuste, ne suffit plus à garantir l'identité d'un utilisateur. La surface d'attaque identifiée ciblait prioritairement les comptes dépourvus de double authentification et l'exploitation potentielle des accès sans fil ouverts du site. L'analyse de risques révisée a ainsi classé comme prioritaires le déploiement immédiat d'une authentification forte et la centralisation absolue des traces de connexion.

PARTIE 3 - ARCHITECTURE CIBLE ET SERVICES DE SÉCURITÉ DÉPLOYÉS

1. Schéma général de l'infrastructure évoluée

L'architecture réseau cible matérialise l'intégration des nouveaux services cyber de manière transversale. Le cœur de réseau assure l'interconnexion sécurisée des différents segments logiques isolés (VLAN) où chaque flux est désormais inspecté, tracé et soumis à des règles de filtrage étanches.

2. Segmentation Wi-Fi et Portail Captif (VLAN 30)

Afin d'éradiquer la vulnérabilité liée à la clé WPA2-PSK globale, le réseau sans fil a été restructuré. Le **VLAN 30 (WIFI GUEST / MOBILES)** a été configuré de manière totalement isolée des ressources de production. L'accès à ce segment est désormais conditionné par le passage obligatoire à travers un **Portail Captif** sécurisé (HTTPS) instancié directement sur le routeur-pare-feu de l'entreprise.

Le processus applique les règles de sécurité suivantes : blocage systématique de tout flux IP par défaut en couche 3 tant que l'authentification n'est pas validée, redirection automatique des requêtes HTTP/HTTPS vers la mire de connexion sécurisée, traçabilité des adresses MAC et obligation d'acceptation de la charte de sécurité informatique pour les invités. Ce mécanisme garantit la parfaite identification des utilisateurs tiers conformément aux obligations légales de conservation des données de connexion.

3. Gestion de la Cybersécurité opérationnelle : Le Service SIEM (VLAN 20)

Le cœur du dispositif de surveillance repose sur le déploiement d'un service de gestion des informations et des événements de sécurité (**SIEM - Security Information and Event Management**), positionné au sein du **VLAN 20 (SERVER)** sous adressage IP fixe.

Ce service assure la collecte continue des événements générés par l'ensemble des composants de l'infrastructure d'Intersport (commutateurs de distribution, contrôleur Wi-Fi, pare-feu de frontière, serveurs de fichiers et contrôleurs de domaine Active Directory). Les journaux sont expédiés via des protocoles sécurisés et durcis (Syslog sur TLS / WinRM chiffré). Le moteur de corrélation du SIEM analyse ces données en temps réel. Il permet notamment de rapprocher une connexion Wi-Fi distante sur le portail captif avec un comportement d'authentification anormal sur l'annuaire, générant ainsi des alertes instantanées à destination de l'équipe cyber.

4. Refonte de l'Annuaire : AD Local, Synchronisation Entra ID et Stratégie MFA multi-terminaux (YubiKey & Authenticator)

Le cœur névralgique de cette deuxième refonte réside dans la réorganisation complète du contrôle des accès et de la gestion des identités, s'inscrivant directement en réponse à l'attaque par hameçonnage de février 2026.

Restructuration de l'Active Directory Local

L'annuaire Microsoft Active Directory Domain Services (AD DS) local a fait l'objet d'une refonte structurelle. Les anciennes Unités Organisationnelles (UO) ont été intégralement migrées vers une nouvelle arborescence standardisée et hiérarchique. Cette nouvelle topologie sépare distinctement les objets par typologie (utilisateurs internes, prestataires, postes de travail, serveurs de production, comptes de services). Cette clarté structurelle permet l'application fine de stratégies de groupe (GPO) restrictives, renforçant le durcissement (hardening) des configurations des postes clients.

Activation de l'Identité Hybride via Microsoft Entra ID

Afin d'ouvrir l'infrastructure vers des mécanismes de sécurité cloud avancés, l'architecture a évolué vers un modèle d'identité hybride. L'outil **Azure AD Connect / Entra Connect** a été déployé sur un serveur membre du VLAN 20. Ce service assure la synchronisation unidirectionnelle sécurisée (chiffrement par hachage des mots de passe) des objets utilisateurs depuis l'Active Directory local vers le tenant cloud **Microsoft Entra ID** d'Intersport France. Cette activation permet d'unifier l'identité des collaborateurs et d'appliquer le contrôle des accès conditionnels.

Mise en production de la Stratégie d'Authentification MFA Multi-Terminaux

Pour faire échec au vol d'identifiants, l'authentification multifacteur (MFA) a été rendue obligatoire pour l'ensemble des collaborateurs lors de l'accès aux ressources locales et cloud. Pour répondre aux contraintes matérielles du parc utilisateur, une stratégie double a été orchestrée :

- **Collaborateurs dotés d'un téléphone mobile professionnel** : La validation du second facteur s'effectue via l'application logicielle **Microsoft Authenticator** via notification Push sécurisée ou code de validation temporaire (TOTP).
- **Collaborateurs SANS téléphone mobile professionnel (Logistique/Technique)** : Afin d'éviter l'usage de téléphones personnels et d'assurer une sécurité maximale, des clés de sécurité matérielles **YubiKey (de chez Yubico)** ont été déployées. Ces clés physiques se connectent en USB ou via NFC aux postes de travail. L'authentification repose sur le standard de sécurité hautement sécurisé **FIDO2 / WebAuthn**, éliminant techniquement tout risque d'interception par phishing, le second facteur étant lié physiquement à la clé possédée par l'utilisateur.

PARTIE 4 - COMPTE RENDU DE DÉPLOIEMENT ET TECHNIQUE DE MIGRATION

1. Phase préparatoire et restructuration des Unités Organisationnelles (UO)

La première phase a consisté à cartographier rigoureusement l'ensemble des comptes utilisateurs et des postes de travail actifs au sein de l'ancien annuaire. Un script PowerShell d'audit a été développé pour identifier les comptes obsolètes ou inactifs. Suite à cela, la nouvelle arborescence d'UO a été créée en parallèle de l'existante pour éviter toute perturbation immédiate.

Les règles de filtrage du pare-feu ont également été adaptées pour autoriser les flux de synchronisation sortants requis par Microsoft Entra ID (Ports HTTPS 443) ainsi que les requêtes d'authentification FIDO2.

2. Cinématique de migration et enrôlement MFA

La migration s'est déroulée selon une cinématique par lots d'utilisateurs (vagues de déploiement) afin de minimiser la charge sur le support informatique :

1. **Migration des objets** : Déplacement des utilisateurs et ordinateurs de l'ancienne structure d'UO vers la nouvelle cible par scripts automatisés, déclenchant l'application des nouvelles GPO de sécurité.
2. **Synchronisation Cloud** : Exécution initiale de l'outil Azure AD Connect pour peupler le répertoire Microsoft Entra ID et validation de la cohérence des identités.
3. **Campagne d'enrôlement MFA** : Distribution des clés physiques YubiKey pour le personnel logistique avec sessions d'appairage initial (génération des paires de clés cryptographiques privées/publiques stockées sur le composant matériel). En parallèle, activation des stratégies d'accès conditionnel forçant l'enrôlement de Microsoft Authenticator pour les cadres et utilisateurs mobiles.

3. Conduite du changement et sensibilisation des collaborateurs

L'introduction d'un second facteur d'authentification (qu'il soit matériel avec la YubiKey ou logiciel avec Authenticator) modifie substantiellement l'expérience utilisateur quotidienne. Une attention particulière a donc été portée à la conduite du changement.

Des ateliers de démonstration de 15 minutes ont été organisés au sein des différents services pour démystifier l'usage des clés de sécurité. Des guides de procédure simplifiés, illustrés pas à pas, ont été diffusés. Cette approche pédagogique a permis de désamorcer les réticences techniques et de lier directement cette contrainte d'authentification à la protection de l'entreprise face aux menaces cyber comme le phishing subi précédemment.

PARTIE 5 - RÉSULTATS, TRAÇABILITÉ ET BILAN PROFESSIONNEL

1. Analyse des résultats et indicateurs cyber

Les résultats mesurés à la suite du déploiement de cette deuxième refonte démontrent une étanchéité complète du système d'information. Le taux d'adoption du MFA a atteint 100 % des utilisateurs actifs, réduisant à un niveau quasi nul le risque d'usurpation de compte par phishing. Les attaques par relecture de mots de passe sont techniquement bloquées par le mécanisme FIDO2 des YubiKeys.

Sur le plan réseau, le portail captif du VLAN 30 isole parfaitement les flux invités, et l'ensemble des connexions (Wi-Fi et AD) est désormais journalisé de manière centralisée dans le SIEM. L'équipe informatique dispose d'une console unique permettant de tracer en temps réel la vie d'une identité de son entrée sur le Wi-Fi jusqu'à ses accès applicatifs.

2. Compétences SISR validées et valorisation personnelle

La réalisation technique de ce projet m'a permis de valider des blocs de compétences majeurs du référentiel du BTS SIO option SISR, notamment dans le domaine de l'administration des systèmes hybrides et de la sécurité des réseaux :

- **Gérer le patrimoine informatique** : Structuration avancée des annuaires d'entreprise et cycle de vie des objets.
- **Répondre aux incidents** : Analyse post-phishing et déploiement de contre-mesures techniques adaptées.
- **Développer la présence en ligne de l'organisation** : Configuration et sécurisation des identités cloud via Microsoft Entra ID.
- **Sécuriser les accès** : Implémentation de portails captifs et d'architectures d'authentification forte matérielle (YubiKey) et logicielle.

3. Évolutions futures du système

En perspective d'évolution, l'infrastructure pourrait intégrer un mécanisme de remédiation automatisée (SOAR) couplé au SIEM, permettant de suspendre instantanément un compte Entra ID ou de révoquer un bail sur le portail captif Wi-Fi en cas de comportement suspect détecté par l'intelligence artificielle du système.

De plus, l'usage des clés YubiKey pourrait être étendu au chiffrement intégral des postes de travail (BitLocker) ou à la signature numérique sécurisée des courriels internes pour éradiquer définitivement la possibilité de phishing à l'identité d'Intersport France.

CONCLUSION GÉNÉRALE

Cette deuxième refonte d'infrastructure marque un tournant décisif dans la sécurisation du système d'information du siège d'Intersport France à Longjumeau. En combinant judicieusement la segmentation réseau par portail captif, la surveillance centralisée via le SIEM et la refonte des identités hybrides (Active Directory / Entra ID) protégées par un MFA robuste (clés physiques YubiKey et Microsoft Authenticator), l'organisation s'est dotée d'une architecture résiliente face aux cybermenaces modernes.

Ce projet illustre parfaitement le rôle d'un technicien supérieur SISR : appréhender des problématiques de sécurité concrètes, adapter les solutions aux réalités humaines et matérielles du terrain, et déployer des technologies de pointe pour garantir la pérennité et la protection des actifs de l'entreprise.